

Incident Response Plan

CONFIDENTIAL

Chelys Security, Inc. · Internal Operations Document · v1.0

DOCUMENT OWNER	Head of Engineering / CISO
EFFECTIVE DATE	May 4, 2026
REVIEW FREQUENCY	Annually, or within 30 days of any P1/P2 incident
VERSION	1.0
CLASSIFICATION	Internal — Confidential. Do not distribute externally.

1. Purpose and Scope

This Incident Response Plan ("IRP") defines how Chelys Security, Inc. detects, contains, eradicates, and recovers from security incidents affecting the Chelys Security platform, its customers, and their data. It applies to all employees, contractors, and systems involved in operating the Service.

Because Chelys Security is itself an offensive security platform, this IRP covers two distinct threat surfaces: **(a) incidents targeting Chelys infrastructure** (the platform being attacked) and **(b) incidents originating from the platform** (agents behaving unexpectedly, customers misusing the Service, or safety controls failing).

2. Incident Severity Classification

LEVEL	NAME	DEFINITION	INITIAL RESPONSE SLA	RESOLUTION SLA
P1	Critical	Confirmed breach of customer data; agent scope escape with confirmed unauthorized access; Safety Oracle bypass; platform-wide outage; active exploitation of Chelys infrastructure	15 minutes	4 hours (containment); 24 hours (public statement if needed)
P2	High	Suspected (unconfirmed) data breach; customer AUP violation with evidence of unauthorized scanning; credential	1 hour	24 hours (containment); 72 hours (resolution)

LEVEL	NAME	DEFINITION	INITIAL RESPONSE SLA	RESOLUTION SLA
		exposure (NTLM hashes, cloud keys); significant service degradation		
P3	Medium	Isolated account compromise; suspicious login activity; agent producing anomalous output without confirmed harm; partial service disruption; third-party sub-processor incident	4 hours	5 business days
P4	Low	Failed login attempts below threshold; potential policy violation with no confirmed harm; vulnerability reported via responsible disclosure with no active exploitation	1 business day	30 days

3. Incident Response Team (IRT)

ROLE	RESPONSIBILITIES	CONTACT
Incident Commander (IC)	Owens the incident end-to-end; makes final decisions on containment and communication; declares severity; authorizes customer notification	CEO / Head of Engineering
Security Lead	Technical investigation; log analysis; containment actions; coordinates with sub-processors; produces post-mortem	security@chelyssecurity.com
Engineering On-Call	Executes technical remediation; deploys patches; revokes compromised credentials; kills runaway agent jobs	PagerDuty rotation
Customer Success	Drafts and sends customer notifications; manages customer questions during and after incident	Internal Slack #incidents
Legal / Compliance	Advises on notification obligations (GDPR 72-hour rule, state breach laws); preserves privilege on communications; coordinates law enforcement if needed	legal@chelyssecurity.com

4. Response Phases

PHASE 1 Detect & Triage 0–15 min (P1)	PHASE 2 Contain 15 min–4 hr	PHASE 3 Eradicate 4–24 hr	PHASE 4 Recover 24–72 hr	PHASE 5 Post-Incident Within 7 days
---	---	---	--	---

Phase 1 — Detect & Triage

1. Incident is detected via alert, customer report, employee observation, or automated monitoring.
2. First responder logs the incident in the incident tracking system with: timestamp, reporter, initial description, affected systems.
3. First responder assigns initial severity (P1–P4) and pages the Incident Commander.
4. IC convenes the IRT in the dedicated incident channel (#incident-YYYY-MM-DD) within 15 minutes (P1/P2) or 1 hour (P3).
5. IC confirms or adjusts severity classification. If P1 or P2, Legal is immediately notified to assess notification obligations.

Phase 2 — Contain

1. Isolate affected systems, accounts, or agent jobs to prevent further damage. Do not destroy evidence.
2. Preserve logs: export relevant PostgreSQL tables, agent event logs, and audit log entries before any system changes.
3. Revoke compromised credentials (API keys, JWT secrets, user sessions) via the admin panel or directly in the database.
4. If a scan job is implicated: kill the Celery task immediately via `celery -A workers.celery_app control revoke [task_id] --terminate`.
5. If a customer account is implicated in AUP violation: suspend the account via the admin API.
6. Block attacker IPs at the infrastructure level (AWS Security Groups / WAF) if actively attacking the platform.

Phase 3 — Eradicate

1. Identify root cause: review audit logs, agent event logs, and application logs for the attack vector or failure point.
2. Remove attacker access: rotate all potentially exposed secrets (JWT_SECRET_KEY, ANTHROPIC_API_KEY, database passwords, Stripe keys).
3. Patch the vulnerability or misconfiguration that enabled the incident.
4. Scan Chelys platform itself for indicators of compromise (IOCs) using appropriate tooling.
5. If customer data was exfiltrated: identify exactly which records, which org, and the time window of exposure.
6. Confirm eradication with the Security Lead before proceeding to recovery.

Phase 4 — Recover

1. Restore affected services from clean backups if systems were compromised.
2. Re-enable suspended accounts or services only after confirming the threat is fully eradicated.
3. Issue new credentials to affected customers as needed.
4. Increase monitoring sensitivity for 30 days post-incident to detect recurrence.
5. Send final customer notification confirming resolution (see Section 7).

Phase 5 — Post-Incident Review

1. Conduct blameless post-mortem within 7 days of incident closure. All IRT members attend.
2. Document: timeline, root cause, customer impact, what worked, what failed, action items.
3. Assign owners and deadlines to every action item. Track in engineering backlog.
4. Update this IRP if the incident revealed gaps in procedures.
5. File incident record in the compliance archive (required for SOC2).

5. Incident Playbooks

Playbook A — Platform Breach / Unauthorized Access to Chelys Infrastructure

P1

Indicators

- Unexpected admin account creation or privilege escalation in audit log
- Login from unrecognized IP or country for internal admin accounts
- Database queries reading cross-org data detected in slow query log
- Unexpected outbound data transfer from production servers

Immediate Actions

- 1 Revoke all active sessions: `DELETE FROM user_sessions` or rotate `JWT_SECRET_KEY` (invalidates all tokens platform-wide).
- 2 Lock the compromised account: `UPDATE users SET is_active = false WHERE email = '[account]';`
- 3 Export `audit_log` table for the last 72 hours before any changes.
- 4 Rotate: `ANTHROPIC_API_KEY`, `STRIPE_SECRET_KEY`, `JWT_SECRET_KEY`, `DATABASE_URL` password, Redis AUTH.
- 5 Notify Legal immediately — GDPR 72-hour clock starts if EU customer data was accessed.
- 6 Engage AWS support if EC2/RDS instances are suspected to be compromised.

Indicators

- Unauthorized SELECT on credentials-related tables detected in DB logs
- Credentials appearing in external breach databases (via monitoring)
- Customer reports their credentials being used from an unknown source

Immediate Actions

- 1 Identify which org(s) and which credential records were exposed. Query: `SELECT org_id, service, created_at FROM provided_credentials WHERE updated_at BETWEEN [window];`
- 2 Notify affected customers immediately — do not wait for full investigation. Use the breach notification template in Section 7.
- 3 Instruct customers to rotate all exposed credentials immediately.
- 4 Purge all credential records for affected org(s) from the database.
- 5 Accelerate field-level encryption implementation if not yet complete — this is the root cause gap.

Indicators

- Safety Oracle log shows out-of-scope target contacted without block record
- Agent event log shows tool calls to IPs outside the job's defined scope
- Third-party reports receiving unexpected scan traffic from Chelys IP ranges
- Nmap, Nuclei, or Metasploit logs show targets not in the job's target_ids list

Immediate Actions

- 1 Kill the offending job immediately: `celery -A workers.celery_app control revoke [task_id] --terminate`. Then: `UPDATE jobs SET status = 'cancelled' WHERE id = '[job_id]';`
- 2 Preserve all agent event logs for the job before any cleanup.
- 3 Identify the out-of-scope target(s) and assess what actions were taken against them.
- 4 Notify the owner of the inadvertently scanned target if contact information is obtainable and meaningful access occurred.
- 5 Suspend all active jobs for the affected customer account pending investigation.
- 6 File a Safety Oracle bug — identify whether the bypass was due to a scope enforcer defect, agent prompt injection, or misuse.

Indicators

- Third-party complaint: organization reports receiving scan traffic they did not authorize
- Audit log shows customer scanning IP ranges with no plausible ownership connection
- Law enforcement or legal contact regarding a customer's scanning activity

Immediate Actions

- 1 Suspend the customer account immediately: `UPDATE users SET is_active = false WHERE org_id = '[org_id]';`
- 2 Kill all active jobs for the org: `UPDATE jobs SET status = 'cancelled' WHERE org_id = '[org_id]' AND status = 'running';`
- 3 Preserve all audit logs, agent event logs, and job records — do not delete. These may be required by law enforcement.
- 4 Notify Legal. If law enforcement contact has been made, do not contact the customer without Legal's direction.
- 5 Respond to the complaining party confirming the account has been suspended and the activity has stopped.
- 6 Evaluate whether to permanently terminate the account and report to law enforcement per Legal's guidance.

Indicators

- Agent event log shows Claude receiving tool output containing instruction-like text and then changing behavior
- Finding narrative contradicts raw tool evidence (Claude reported system "secure" with no supporting evidence)
- Agent calls tools with parameters not derived from legitimate scan context

Immediate Actions

- 1 Kill the affected job and flag all findings from that job as "requires manual review."
- 2 Export the full Claude prompt/response chain from agent event logs for the job.
- 3 Notify the customer that their job results require manual verification before use.
- 4 Audit all other active jobs for similar indicators — a successful injection technique may be repeatable.
- 5 Implement or strengthen untrusted-data delimiters in all Claude prompts that include tool output. Deploy immediately to all workers.

Indicators

- Login from new country or IP flagged by audit log monitoring
- Customer reports they did not initiate a scan that appears in their job history
- Multiple failed MFA attempts followed by successful login

Immediate Actions

- 1 Invalidate all sessions for the user: rotate JWT secret or delete user's active tokens.
- 2 Force password reset and MFA re-enrollment.
- 3 Review the user's audit log for any unauthorized actions taken during the compromise window.
- 4 If unauthorized scans were run, follow Playbook D for affected targets.
- 5 Notify the customer of the incident, actions taken, and recommended next steps (enable MFA, review API keys).

6. Evidence Preservation

Critical: Never delete, overwrite, or modify evidence before Legal authorizes it. Tampering with logs during an active security incident or law enforcement investigation is a criminal offense.

At the start of any P1 or P2 incident, the Security Lead must immediately export and archive:

- **Audit log:** `SELECT * FROM audit_log WHERE created_at > now() - interval '7 days';` → export as CSV
- **Agent event logs:** All records for implicated job IDs
- **PostgreSQL slow query log** for the relevant time window
- **Application logs** from the API and worker containers (Docker logs)
- **AWS CloudTrail / VPC Flow Logs** if infrastructure compromise is suspected

Store evidence in an isolated, access-controlled S3 bucket or encrypted archive. Log all access to the evidence archive.

7. Customer Notification

Notification Triggers

- **P1:** Notify affected customers within **24 hours** of incident confirmation, regardless of investigation completion
- **P2:** Notify within **72 hours** of confirmation

- **P3/P4:** Notify if customer data or operations were materially affected

GDPR Requirement: If the incident involves personal data of EU/UK residents, the relevant supervisory authority must be notified within **72 hours** of Chelys becoming aware of the breach (Article 33 GDPR). Legal must be notified immediately for any P1/P2 with EU data exposure.

Initial Customer Notification Template

Subject: [SECURITY NOTICE] Incident Affecting Your Chelys Security Account

Dear [Customer Name],

We are writing to inform you of a security incident that may affect your organization's data on the Chelys Security platform.

WHAT HAPPENED

On [date/time UTC], we detected [brief description – e.g., "unauthorized access to our database" / "a misconfigured access control affecting your account"]. We became aware of this at [time UTC].

WHAT DATA WAS AFFECTED

[Specify exactly: e.g., "Vulnerability findings from jobs run between X and Y dates" / "Credentials you provided for job ID Z" / "No customer data was confirmed to be accessed."]

WHAT WE HAVE DONE

- [Action 1, e.g., "Terminated unauthorized access within 15 minutes of detection"]
- [Action 2, e.g., "Rotated all platform API keys and invalidated all active sessions"]
- [Action 3, e.g., "Engaged a third-party forensic firm to conduct a full investigation"]

WHAT YOU SHOULD DO

- [Action for customer, e.g., "Immediately rotate the credentials you provided for testing"]
- [Action, e.g., "Review your audit log at /audit for any unexpected activity"]
- [Action, e.g., "Enable MFA on your account if not already active"]

We will provide a follow-up update within [48/72] hours with the results of our full investigation.

If you have questions, please contact us at security@chelyssecurity.com.

We sincerely apologize for this incident and any disruption it causes.

[Name]

[Title]

Chelys Security, Inc.

8. Responsible Disclosure — Receiving External Reports

Security researchers who discover vulnerabilities in the Chelys platform may report them to **security@chelyssecurity.com**. Chelys commits to:

- Acknowledge receipt within **2 business days**
- Provide a preliminary assessment within **7 business days**
- Work with the reporter on a coordinated disclosure timeline (typically 90 days)
- Not pursue legal action against researchers acting in good faith under this policy
- Credit the reporter in the fix announcement (unless they prefer anonymity)

Reports must include: steps to reproduce, affected component, potential impact, and researcher contact information. Researchers must not access customer data beyond what is necessary to demonstrate the vulnerability, and must not disclose publicly before the agreed disclosure date.

9. Post-Incident Review Template

INCIDENT ID	
SEVERITY	
DATE DETECTED	
DATE RESOLVED	
TOTAL DURATION	
CUSTOMERS AFFECTED	
ROOT CAUSE	
TIMELINE SUMMARY	
WHAT WORKED WELL	
WHAT FAILED	
ACTION ITEMS (OWNER / DUE DATE)	
IRP UPDATE REQUIRED?	☐ Yes ☐ No
IC SIGN-OFF	

10. Document Control and Review

This IRP must be reviewed and updated:

- Annually (minimum), by the Head of Engineering and Legal
- Within 30 days of any P1 or P2 incident
- When significant changes are made to the platform architecture, sub-processors, or team structure
- Before SOC2 Type I or Type II audit readiness assessments

SOC2 Note: This IRP, along with incident records and post-mortems, constitutes evidence for SOC2 CC7.3 (incident response) and CC7.4 (incident communication). Ensure all P1/P2 incidents are documented in the compliance archive with timeline, root cause, and resolution within 7 days of closure.